

Guía De Interpretación: NIST SP 800-86

Carolina Salinas
David Mora Fierro
Juan Nikolas Hernández
Johana Iden Lambuley Contreras

Jaider Ospina

Maestría En Ciberseguridad y Ciberdefensa

Escuela Superior de Guerra "General Rafael Reyes Prieto"
Bogotá D.C., Colombia
2026

GUÍA DE INTERPRETACIÓN: NIST SP 800-86

Guía para Integrar Técnicas Forenses en la Respuesta a Incidentes (*Guide to Integrating Forensic Techniques into Incident Response*)

OBJETIVO, ALCANCE Y MARCO DE REFERENCIA TÉCNICO

Objetivo
Sintetizar y operativizar las directrices del **NIST SP 800-86**, estableciendo un marco técnico riguroso y repetible para la recolección, examen, análisis y reporte de evidencia digital durante la contención y erradicación de incidentes de seguridad, garantizando la preservación probatoria frente a auditorías internas o instancias judiciales.

Perímetro de Aplicación Técnica
Aplica a incidentes de seguridad en infraestructuras locales, virtuales o híbridas donde interactúen tres fuentes principales de datos:

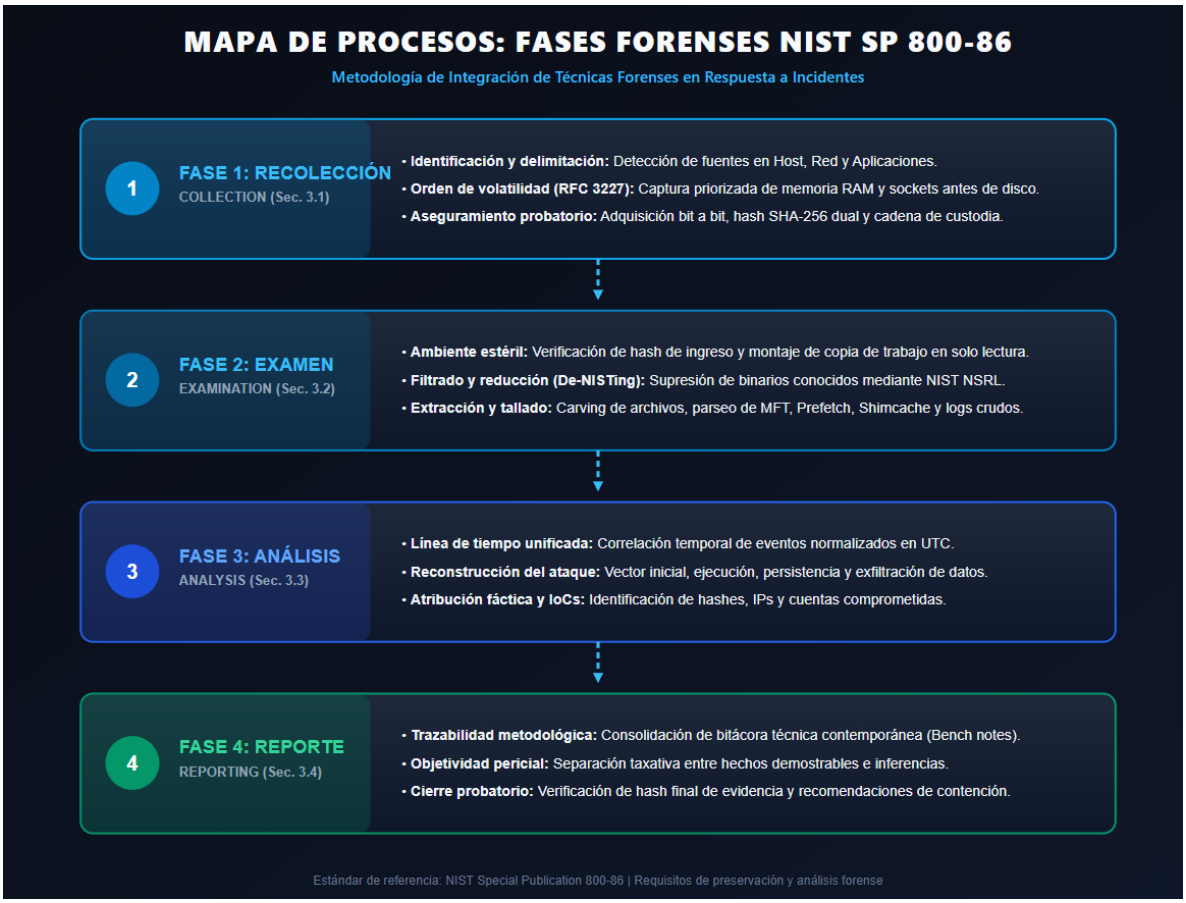
- **Sistemas Anfitriones (Hosts):** Memoria volátil (RAM), espacio no asignado (*slack space*), registros del sistema operativo, estructuras de archivos (MFT, artefactos de ejecución) y volcados de disco.
- **Redes (Network Devices):** Trazas completas de paquetes (PCAP), registros de flujo (*NetFlow/IPFIX*), tablas de enrutamiento y logs de dispositivos perimetrales (Firewalls, IDS/IPS, Proxies).
- **Aplicaciones y Servicios:** Logs transaccionales de bases de datos, servicios web, servidores de autenticación (Active Directory, LDAP, IAM) y plataformas de correo.

Infraestructura, Hardware Homologado y Ambiente Estéril

- **Bloqueadores de Escritura Físicos (*Write-Blockers*):** Puentes forenses de hardware (SATA/SAS, NVMe, USB 3.0) certificados bajo el programa NIST CFTT (*Computer Forensic Tool Testing*), configurados en modo estricto de solo lectura (*read-only*).
- **Medios de Almacenamiento Estériles:** Unidades receptoras sometidas previamente a borrado seguro de patrones (*zero-fill* de un pase o DoD 5220.22-M), con verificación previa de hash nulo en todos sus sectores.
- **Estación de Trabajo Forense Aislada (*Forensic Workstation*):** Entornos de análisis *air-gapped* (sin interfaz física ni lógica a redes externas), con puertos no esenciales bloqueados a nivel de BIOS/UEFI y montaje de imágenes forenses exclusivamente en modo de solo lectura (mount -o ro,loop,noexec).

2. MAPA DE PROCESOS: FASES FORENSES NIST SP 800-86

NIST SP 800-86 estructura el ciclo de vida del análisis forense aplicado a incidentes en cuatro fases continuas, interconectadas e iterativas:



3. PROCEDIMIENTO SECUENCIAL OPERATIVO Y ASEGURAMIENTO CRIPTOGRÁFICO

Procedimiento Técnico Estandarizado (Modo Imperativo)

1. **Asegurar la Escena Digital y Evaluar la Volatilidad:**
   - Evaluar el estado operativo del equipo. Si se encuentra encendido, **no desconectar de la energía** ni apagar el sistema operativo.
   - Aislar el host de la red mediante desconexión física del cable Ethernet o inhabilitación de interfaces inalámbricas, sin suspender los procesos activos.
2. **Ejecutar la Adquisición Volátil en Memoria (RFC 3227):**
   - Conectar un medio USB estéril previamente configurado con binarios forenses estáticos o herramientas portables validadas (ej. WinPmem, LiME).
   - Ejecutar la adquisición de memoria RAM completa, volcando la imagen en crudo (.raw o .bin) directamente hacia el medio externo.

    - Documentar inmediatamente la hora exacta del volcado en formato UTC, el comando ejecutado y los mensajes arrojados por el aplicativo.
3. **Calcular y Registrar el Hash Criptográfico Dual:**
    - Calcular de inmediato los valores hash **SHA-256** y **SHA-3** sobre el archivo de imagen de memoria obtenido.
    - Registrar las cadenas alfanuméricas resultantes en el formulario formal de cadena de custodia.
4. **Adquirir el Almacenamiento No Volátil (Disco Bit a Bit):**
    - Apagar de forma controlada el equipo si las políticas operativas lo exigen (ej. extracción de batería o desconexión del cable de poder de la fuente en equipos de escritorio para evitar scripts de apagado malicioso).
    - Conectar la unidad de almacenamiento al bloqueador de escritura físico por hardware.
    - Adquirir una imagen bit a bit (*bit-stream image*) en formato pericial estandarizado (.E01 o .dd/raw) hacia el disco de destino estéril.
    - Verificar que el valor hash de verificación generado al cierre de la clonación coincida matemáticamente con el disco de origen.
5. **Generar la Copia de Trabajo en Laboratorio:**
    - Guardar la imagen original en bóveda bajo control de acceso.
    - Clonar una copia exacta de trabajo sobre el almacenamiento estéril de la estación forense para procesar el examen exclusivamente sobre esta réplica.
6. **Ejecutar el Examen y Filtrado de Datos:**
    - Montar la copia de trabajo en modo de solo lectura.
    - Filtrar archivos conocidos del sistema operativo mediante la base de datos de hashes conocidos del NIST (NSRL) para aislar binarios extraños o modificados.
    - Extraer artefactos del registro, historiales de eventos de seguridad (.evtx), archivos de paginación (pagefile.sys), espacio no asignado y cachés del sistema.
7. **Correlacionar Hallazgos y Construir la Cronología:**
    - Unificar los tiempos de los registros del host con los logs del firewall, proxy e IDS perimetrales, corrigiendo cualquier desviación de reloj local (*clock skew*) con respecto a la hora UTC.
    - Reconstruir la secuencia lógica de eventos para identificar la cuenta de usuario empleada, el proceso ejecutor y los posibles datos exfiltrados.
8. **Consolidar la Bitácora y Emitir el Dictamen:**
    - Integrar la bitácora técnica contemporánea (*bench notes*) con la descripción de herramientas, versiones y parámetros empleados para garantizar la repetibilidad técnica.

Aseguramiento Criptográfico y Cadena de Custodia

Esquema de Hashing Dual

Se debe implementar un esquema de autenticación matemática redundante e independiente:

Validez de Integridad ⇔ $Hash_{Adquisición}$ (SHA-256) == $Hash_{Análisis}$ & (SHA-256) $Hash_{Adquisición}$ (SHA-3) == $Hash_{Análisis}$ (SHA-3)

Formato Estricto de Registro de Cadena de Custodia (NIST SP 800-86)

Parámetro Requerido	**Registro Operativo Obligatorio**
Identificador del Caso:	Código único asignado al incidente (ej. INC-2026-NIST-042).
Elemento Probatorio:	Número de ítem (ej. EVID-HOST-01, EVID-MEM-01).
Datos de Origen del Hardware:	Fabricante, modelo, número de serie, capacidad nominal en bytes.
Algoritmos Hash y Valores:	Resultado completo de SHA-256 y SHA-3 calculados al cierre de captura.
Nombre del Custodio Actual:	Nombre completo, documento de identidad, área y cargo.
Nombre del Receptor Técnico:	Nombre completo, documento de identidad, área y cargo.
Fecha, Hora y Zona:	Registro temporal normalizado (YYYY-MM-DD hh:mm:ss UTC).
Propósito de Transferencia:	Adquisición primaria, ingreso a laboratorio forense, preservación en bóveda.
Firmas de Responsabilidad:	Rúbrica manuscrita o firma digital con certificado válido de emisor y receptor.

4. CHECKLIST DE CUMPLIMIENTO PERICIAL (NIST SP 800-86)

Lista de verificación para validar que el procedimiento de respuesta técnica y forense cumple los requisitos de confiabilidad y admisibilidad del estándar:

ID	Control Técnico Requerido	Criterio de Verificación Operativa	Cumple (S/N/NA)
CHK-N01	**Respeto al Orden de Volatilidad**	Se recolectaron las fuentes volátiles (RAM, conexiones, procesos) antes que las unidades fijas de almacenamiento secundario (RFC 3227 / NIST SP 800-86 Sec. 3.1).	[ ]
CHK-N02	**Aislamiento No Destructivo**	Se aisló el sistema del entorno de red sin forzar el apagado intempestivo ni destruir artefactos en memoria volátil.	[ ]
CHK-N03	**Bloqueo Físico de Escritura**	Se empleó un puente bloqueador de hardware verificado en modo solo lectura para la extracción de dispositivos físicos de almacenamiento.	[ ]
CHK-N04	**Integridad Criptográfica Verificada**	Se computaron y documentaron hashes SHA-256/SHA-3 en el punto de captura y se contrastaron antes de iniciar el examen técnico.	[ ]
CHK-N05	**Uso Exclusivo de Copia de Trabajo**	La imagen original máster quedó intacta bajo custodia; todas las acciones analíticas se ejecutaron sobre un duplicado bit a bit montado en modo de solo lectura.	[ ]
CHK-N06	**Validación de Herramientas (CFTT)**	Las herramientas empleadas se encuentran testeadas y validadas documentalmente para certificar que no alteran los datos del medio original.	[ ]

ID	Control Técnico Requerido	Criterio de Verificación Operativa	Cumple (S/N/NA)
CHK-N07	**Cadena de Custodia Ininterrumpida**	Existe constancia documental firmada de cada traspaso, traslado y cambio de almacenamiento de la evidencia desde su captura.	[ ]
CHK-N08	**Documentación Contemporánea**	El analista mantuvo bitácora de notas en tiempo real registrando comandos, rutas de ejecución y salidas de software para garantizar repetibilidad.	[ ]
CHK-N09	**Normalización Temporal UTC**	Todos los eventos temporales de hosts, red y aplicaciones fueron convertidos a UTC y ajustados por desfase de reloj (*clock skew*).	[ ]
CHK-N10	**Objetividad en el Reporte**	El informe pericial consigna exclusivamente hechos demostrables con base en la evidencia técnica, absteniéndose de juicios penales de dolo o culpabilidad.	[ ]

5. GLOSARIO TÉCNICO-JURÍDICO Y ALCANCE/LIMITACIONES

Glosario Técnico-Jurídico Crítico

- **Orden de Volatilidad (*Order of Volatility*):** Secuencia técnica estandarizada (derivada de la RFC 3227 y adoptada por el NIST) que dicta la adquisición de evidencia según su tiempo de vida útil antes de desaparecer: registros de CPU/caché = tablas de enrutamiento/caché ARP/procesos/memoria RAM = sistema de archivos temporales = disco magnético/SSD = logs remotos = medios de respaldo en cinta.

- **Imagen Bit a Bit (*Bit-Stream Image*):** Duplicación física exacta, sector por sector y bit por bit de un medio digital, incluyendo sectores no asignados (*unallocated space*), espacio holgado (*slack space*) y metadatos del sistema de archivos.
- **De-NISTing:** Proceso de filtrado y exclusión de archivos comunes y no alterados del sistema operativo o software comercial mediante cotejo de hashes contra la *National Software Reference Library* (NSRL) del NIST, reduciendo significativamente el volumen de datos a examinar.
- **Espacio Holgado (*Slack Space*):** Espacio no utilizado que queda entre el final de un archivo real y el final del clúster físico asignado por el sistema de archivos, fuente habitual de fragmentos de evidencia remanente.
- **Tallado de Archivos (*File Carving*):** Técnica de extracción forense que recupera archivos eliminados a partir del análisis de sus cabeceras (*headers*) y pies de página (*footers*) binarios directamente en el flujo de bytes, sin depender de la tabla de asignación de archivos del sistema operativo.
- **Cadena de Custodia (*Chain of Custody*):** Registro documental cronológico ininterrumpido que acredita la recolección, custodia, control, transferencia, análisis y disposición final de la evidencia digital, garantizando que el material presentado ante una autoridad es idéntico al recolectado.
- **Repetibilidad Operativa (*Repeatability*):** Capacidad de que el mismo analista, aplicando los mismos comandos y herramientas sobre el mismo conjunto de datos bajo las mismas condiciones de laboratorio, obtenga exactamente el mismo resultado técnico.
- **Admisibilidad de la Evidencia (*Evidentiary Admissibility*):** Juicio jurídico mediante el cual un tribunal determina si un elemento probatorio digital satisface los requisitos legales y técnicos de autenticidad, integridad y confiabilidad metodológica (criterios *Daubert/Frye* y reglas locales de prueba).

Alcance y Limitaciones del Estándar NIST SP 800-86

Delimitación de Escenarios No Cubiertos por la Norma

- **No cubre Protocolos Jurídicos Locales:** NIST SP 800-86 es una guía técnica y procedimental de mejores prácticas emanada del gobierno de los Estados Unidos. No reemplaza los códigos de procedimiento penal, normas procesales probatorias ni directrices de policía judicial de jurisdicciones externas.
- **No cubre Criterios Avanzados de Interpretación y Falsación de Hipótesis:** El estándar se concentra en la dimensión operativa de recolección, examen y reporte fáctico. No proporciona un marco epistemológico formal para la formulación y refutación de hipótesis en litigios complejos, aspecto regulado de manera estricta por normas como **ISO/IEC 27042**.
- **No cubre Auditoría de Laboratorios Forenses:** No establece los requisitos de gestión de calidad, acreditación ni calibración de instalaciones periciales (ámbito reservado a **ISO/IEC 17025** e **ISO/IEC 27041**).
- **Dependencia de la Fase de Contención:** Si el equipo de respuesta a incidentes prioriza la restauración del servicio sobre la preservación forense (p. ej., reiniciando servidores o restaurando copias de respaldo antes de adquirir la memoria RAM), la

aplicación posterior de NIST SP 800-86 no puede reparar la evidencia destruida (*Principio de Destrucción Irreversible de la Volatilidad*).

- **Prohibición de Calificación Legal:** El alcance del reporte bajo NIST SP 800-86 es estrictamente técnico-fáctico. El analista describe la secuencia de eventos, los privilegios utilizados y los artefactos comprometidos; tiene prohibido emitir calificaciones penales de dolo, tipicidad o imputación de responsabilidad legal.

GUÍA LITE DE INTERPRETACIÓN: ISO/IEC 27042:2015

Directrices para el Análisis y la Interpretación de Evidencia Digital (*Guidelines for the Analysis and Interpretation of Digital Evidence*)

1. OBJETIVO, ALCANCE Y MARCO DE REFERENCIA TÉCNICO

Objetivo

Sintetizar y operativizar las directrices de la norma **ISO/IEC 27042:2015**, estableciendo un marco metodológico, científico y reproducible para el examen técnico, análisis de hechos, formulación y contraste de hipótesis, y la interpretación contextual de la evidencia digital, asegurando su validez probatoria frente a auditorías y tribunales judiciales.

Perímetro de Aplicación Técnica

Aplica a la fase analítica e interpretativa posterior a la adquisición de la evidencia. El perímetro abarca:

- **Entornos de Datos Preservados:** Imágenes forenses bit a bit de medios de almacenamiento, volcados de memoria volátil (RAM), registros de tráfico de red y bases de datos transaccionales previamente asegurados bajo **ISO/IEC 27037**.
- **Procesos Cognitivos y Analíticos:** Formulación sistemática de hipótesis técnicas (H1, H0, H2), evaluación de explicaciones alternativas, cuantificación de la incertidumbre técnica y mitigación del sesgo de confirmación.
- **Sustentación Pericial:** Emisión de dictámenes periciales donde se deba auditar el razonamiento lógico-deductivo aplicado por el perito.

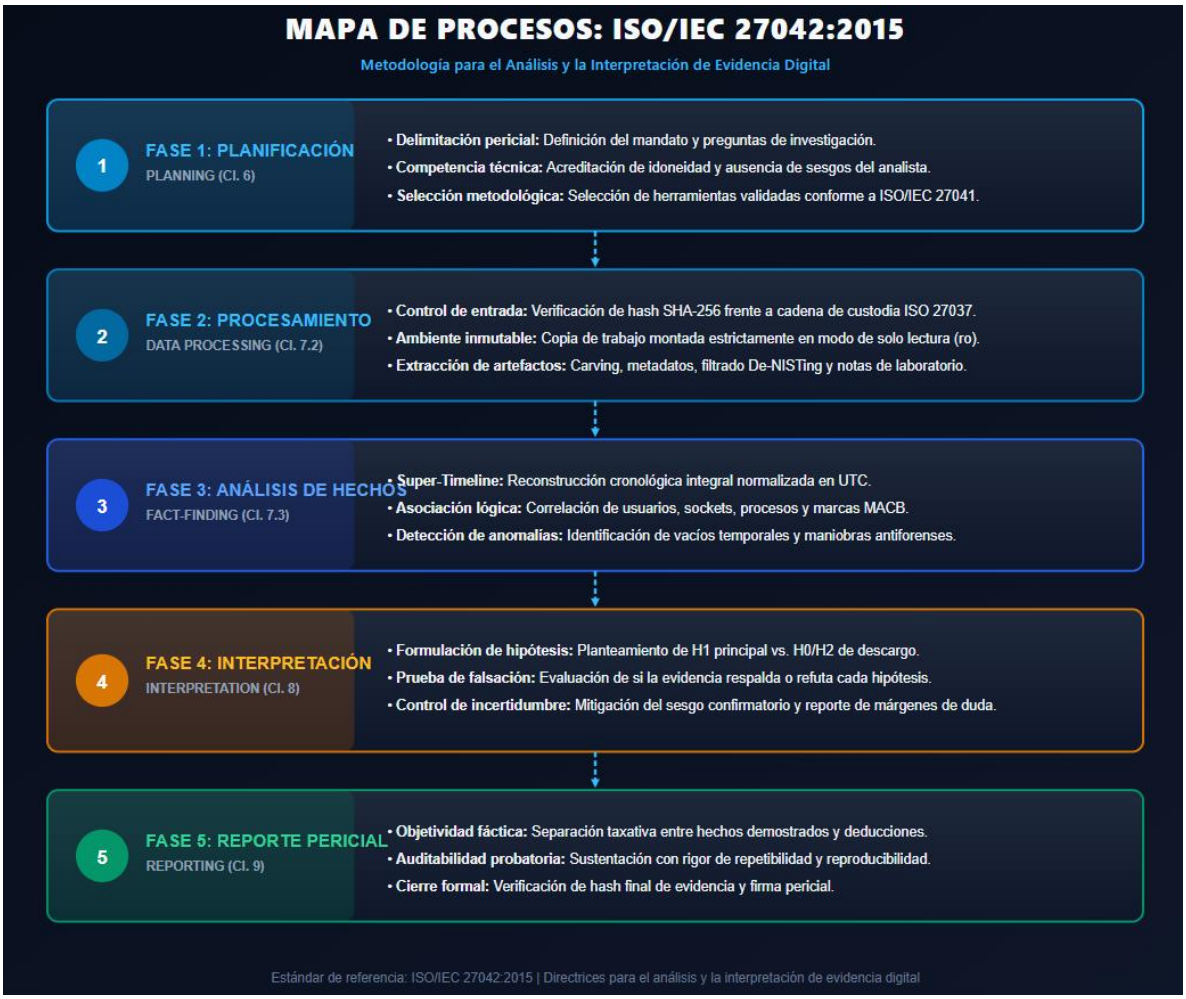
Infraestructura, Hardware Homologado y Ambiente Estéril

- **Estación de Trabajo Forense Aislada (*Forensic Workstation*):** Entornos de análisis *air-gapped* sin conexión a redes públicas o corporativas, con puertos periféricos no autorizados bloqueados a nivel de firmware/BIOS.
- **Medios de Almacenamiento Estériles:** Dispositivos receptores formateados y verificados con patrón de borrado seguro (*zero-fill*), con hash de control nulo previo.
- **Montaje Lógico Inmutable:** Las imágenes de trabajo deben montarse exclusivamente en modo de solo lectura estricto mediante el sistema operativo (mount -o ro,loop,noexec o sistemas de archivos con soporte forense de solo lectura).

- **Validación de Métodos y Herramientas:** Todo software utilizado (de código abierto o comercial) debe contar con validación documental previa conforme a los principios de **ISO/IEC 27041**, garantizando que produce resultados repetibles y no introduce artefactos artificiales.

2. MAPA DE PROCESOS: FASES FORENSES ISO/IEC 27042:2015

ISO/IEC 27042 estructura la investigación en un ciclo secuencial e iterativo dividido en dos grandes dimensiones: el **Análisis** (procesamiento de datos fácticos brutos) y la **Interpretación** (asignación de significado contextual frente a hipótesis rivales).



3. PROCEDIMIENTO SECUENCIAL OPERATIVO Y ASEGURAMIENTO CRIPTOGRÁFICO

Procedimiento Técnico Estandarizado (Modo Imperativo)

1. **Verificar la Integridad Criptográfica de Ingreso:**

    - Calcular de inmediato los valores hash (SHA-256 y SHA-3/512) de las imágenes forenses recibidas antes de efectuar cualquier operación.
    - Contrastar los resultados con el acta de cadena de custodia de entrega (procedente de ISO/IEC 27037). Si los valores no coinciden, rechazar la muestra.
2. **Generar la Copia de Trabajo en Medio Estéril:**
    - Almacenar la imagen réplica original en la bóveda de evidencia digital bajo acceso restringido.
    - Generar una copia forense bit a bit hacia el almacenamiento de trabajo y montarla estrictamente en modo de solo lectura lógica (ro).
3. **Ejecutar el Examen Técnico y Extracción de Artefactos:**
    - Extraer metadatos del sistema de archivos (MFT, $LogFile$, journal), volcados de memoria RAM y registros transaccionales.
    - Aplicar filtrado de archivos conocidos del sistema mediante cotejo de listas de hashes validadas (NSRL) para aislar elementos anómalos.
4. **Construir la Línea Temporal Unificada (*Super-Timeline*):**
    - Normalizar todas las marcas de tiempo (modificación, acceso, creación, nacimiento - MACB) al estándar UTC (ISO 8601).
    - Correlacionar cronológicamente los eventos del sistema operativo con eventos de red y registros de auditoría de aplicaciones.
5. **Formular y Contrastar Hipótesis Periciales (Cláusula Central ISO 27042):**
    - Redactar formalmente la **Hipótesis Principal (H1)** (ej. *"El usuario utilizó credenciales válidas para transferir el archivo X mediante el canal Y"*).
    - Formular explícitamente al menos una **Hipótesis Alternativa (H0/H2)** (ej. *"Un artefacto malicioso ejecutado de manera remota automatizó la transferencia sin conocimiento del usuario"* o *"Ocurrió una alteración de marcas de tiempo vía timestomping"*).
    - Evaluar si la evidencia técnica hallada sustenta, contradice o es neutra frente a cada una de las hipótesis planteadas.
6. **Cuantificar la Incertidumbre Analítica:**
    - Identificar vacíos de datos temporales (*time-gaps*), espacio no asignado sobreescrito o registros de auditoría truncados.
    - Consignar el nivel de certidumbre técnica de los hallazgos sin sobredimensionar las conclusiones.
7. **Documentar y Emitir el Dictamen Pericial:**
    - Registrar en notas contemporáneas (*bench notes*) cada comando, versión de herramienta utilizada y parámetro configurado para garantizar que otro analista obtenga el mismo resultado.
    - Redactar el dictamen pericial diferenciando de forma inequívoca los **hechos comprobados** de las **inferencias técnicas**.

Aseguramiento Criptográfico y Cadena de Custodia

Esquema de Hashing Dual

La integridad de la prueba en la fase analítica descansa en la equivalencia matemática determinista e independiente:

Integridad Analítica⇔ $Hash_{Entrada}$ (SHA-256) == $Hash_{Salida}$ (SHA-256) & $Hash_{Entrada}$ (SHA-3) == $Hash_{Salida}$ (SHA-3)

Formato Estricto de Registro de Cadena de Custodia Analítica (ISO/IEC 27042)

Parámetro Requerido	**Registro Operativo Obligatorio**
Identificador del Caso:	Código de radicado pericial (ej. PER-2026-ISO-27042-019).
Identificador de Evidencia:	Identificador unívoco del contenedor/imagen (ej. EVID-IMG-01).
Descripción del Elemento:	Tipo de contenedor (.E01, .raw, .dd), tamaño exacto en bytes, fuente de adquisición.
Valor Hash de Control (SHA-256):	Hash de 64 caracteres calculado al ingresar al proceso analítico.
Valor Hash de Respaldo (SHA-3/512):	Hash de 128 caracteres para verificación cruzada independiente.
Perito / Analista Responsable:	Nombre completo, documento de identidad, matrícula/acreditación profesional.
Fecha, Hora y Zona:	Marca temporal de inicio y fin de custodia (YYYY-MM-DD hh:mm:ss UTC).
Operación Realizada:	Extracción de metadatos, análisis de memoria, contraste de hipótesis, archivo en bóveda.
Declaración de Integridad:	Firma digital o manuscrita certificando la ausencia de alteraciones en el soporte analizado.

4. CHECKLIST DE CUMPLIMIENTO PERICIAL (ISO/IEC 27042)

Lista de verificación para validar que el procedimiento analítico cumple con los estándares de rigor científico, validez probatoria y admisibilidad judicial (*Daubert/Frye*):

ID	Control Obligatorio	Criterio de Verificación Normativo	Cumple (S/N/NA)
CHK-I01	**Competencia del Analista**	El perito cuenta con formación demostrable, experiencia y habilidades acreditadas para el análisis específico que realiza (ISO/IEC 27042 Cl. 6.2).	[ ]
CHK-I02	**Integridad Criptográfica de Entrada**	Verificación documentada de que el valor hash de la imagen de trabajo coincide al 100% con el hash de la evidencia original preservada.	[ ]
CHK-I03	**Repetibilidad (*Repeatability*)**	El perito documentó parámetros, scripts y comandos de modo que **el mismo analista** en el mismo entorno obtenga idénticos resultados (ISO 27042 Cl. 7.3).	[ ]
CHK-I04	**Reproducibilidad (*Reproducibility*)**	La metodología descrita permite que **un perito independiente**, aplicando métodos equivalentes, arribe a las mismas conclusiones fácticas (ISO 27042 Cl. 7.4).	[ ]
CHK-I05	**Idoneidad de Herramientas**	Se emplearon herramientas forenses cuya confiabilidad fue validada y documentada previamente frente a fallos o alteración de datos (ISO/IEC 27041).	[ ]
CHK-I06	**Formulación de Hipótesis Alternativas**	Se plantearon y evaluaron explícitamente hipótesis de descargo o explicaciones técnicas	[ ]

ID	Control Obligatorio	Criterio de Verificación Normativo	Cumple (S/N/NA)
		contrarias a la acusación/reclamo principal (ISO 27042 Cl. 8.4).	
CHK-I07	**Mitigación del Sesgo Cognitivo**	Se aplicaron controles para neutralizar el *sesgo de confirmación*, examinando la evidencia exculpatoria con el mismo rigor que la inculpatoria.	[ ]
CHK-I08	**Bitácora Contemporánea (*Bench Notes*)**	Se mantuvieron notas técnicas de trabajo fechadas cronológicamente en tiempo real, registrando cada decisión y hallazgo del análisis.	[ ]
CHK-I09	**Distinción Hecho vs. Interpretación**	El informe pericial separa de manera tajante los **hechos técnicos comprobables** de las **inferencias e interpretaciones** del perito.	[ ]
CHK-I10	**Declaración Expresa de Incertidumbre**	Se delimitaron con precisión los márgenes de error, vacíos de información o limitaciones tecnológicas que condicionan las conclusiones del dictamen.	[ ]

5. GLOSARIO TÉCNICO-JURÍDICO Y ALCANCE/LIMITACIONES

Glosario Técnico-Jurídico Crítico

- **Análisis (*Analysis*):** Proceso metódico de evaluación y extracción de datos desestructurados con el fin de identificar artefactos, reconstruir cronologías y establecer hechos comprobables de manera técnica e independiente.
- **Interpretación (*Interpretation*):** Proceso cognitivo y deductivo mediante el cual el perito atribuye significado contextual a los hechos descubiertos durante el análisis, vinculando la evidencia con los sucesos investigados.

- **Repetibilidad (*Repeatability*):** Principio forense que establece que un mismo analista, trabajando en el mismo laboratorio, con las mismas herramientas y el mismo conjunto de datos, debe obtener resultados idénticos.
- **Reproducibilidad (*Reproducibility*):** Principio procesal y probatorio según el cual un perito distinto, trabajando en un laboratorio diferente y con herramientas técnicas análogas pero independientes, alcanza las mismas conclusiones sustantivas sobre la evidencia.
- **Contraste de Hipótesis (*Hypothesis Testing*):** Metodología científica exigida por la norma en la que se formulan hipótesis rivales (H1 frente a H0/H2) y se someten a pruebas de falsación mediante los artefactos hallados para descartar explicaciones erróneas.
- **Sesgo de Confirmación (*Confirmation Bias*):** Tendencia cognitiva del investigador a buscar, interpretar o favorecer únicamente la información que confirma sus creencias preconcebidas o la hipótesis de quien contrata el peritaje; ISO 27042 exige su mitigación activa.
- **Incertidumbre Analítica (*Analytical Uncertainty*):** Reconocimiento técnico del margen de duda inherente a la pericia, motivado por sobreescritura de espacio no asignado, truncamiento de logs, desfase horario o ausencia de artefactos corroborantes.
- **Admisibilidad Probatoria (*Admissibility of Evidence*):** Idoneidad jurídica de un informe pericial para ser valorado formalmente por un juez, condicionada a que sus métodos posean rigor científico, repetibilidad y ausencia de arbitrariedad técnica (*estándares Daubert/Frye*).

Alcance y Limitaciones del Estándar ISO/IEC 27042:2015

Deslinde dentro de la Suite Forense ISO

- **No cubre Adquisición ni Preservación:** La norma no establece cómo recolectar evidencias físicas o lógicas ni cómo acordonar la escena digital; esto es competencia exclusiva de **ISO/IEC 27037**. ISO 27042 presupone que la evidencia ya fue legal y técnicamente preservada.
- **No cubre Validación General de Software:** La metodología para certificar que una herramienta de software forense es apta para su uso está regulada por **ISO/IEC 27041**, no por la 27042.
- **No cubre la Gestión Global de Incidentes:** La orquestación institucional del incidente, las comunicaciones de crisis y la mitigación corporativa están fuera de su alcance, correspondiendo a **ISO/IEC 27043** e **ISO/IEC 27035**.

Limitaciones Técnicas y de Entorno

- **Inexistencia de Prescripciones de Software:** ISO/IEC 27042 define principios metodológicos y epistemológicos; no prescribe sistemas operativos específicos, herramientas comerciales particulares ni comandos exactos.

- **Dependencia de la Calidad de Entrada (*GIGO*):** La norma no puede sanear fallas ocurridas en la recolección. Si la imagen forense fue mal adquirida o adulterada en origen, las conclusiones del análisis carecerán de validez probatoria.

Frontera Jurídica y Prohibición de Tipicidad Penal

- **Supremacía del Derecho Procesal Local:** La norma es un estándar técnico internacional de buenas prácticas y no reemplaza los códigos procesales ni las leyes de evidencia de cada jurisdicción.
- **Prohibición de Calificaciones Penales:** El perito bajo ISO/IEC 27042 debe limitar sus conclusiones a la certeza técnica (*"el archivo fue transmitido desde la sesión del usuario mediante el puerto 443"*); tiene **terminantemente prohibido** tipificar delitos o calificar culpabilidad (*"el usuario cometió fraude informático"* o *"actuó con negligencia dolosa"*), dado que la calificación jurídica es competencia exclusiva del juez o tribunal competente.